Google Cloud

Implementación de controles de seguridad

Como ya aprendiste, los controles de seguridad son medidas de protección importantes que ayudan a reducir el riesgo. También aprendiste los pasos que puedes seguir para elegir y aplicar los controles contra riesgos o amenazas específicos. En esta lectura, aprenderás más sobre las prácticas recomendadas para implementar controles de seguridad y analizarás un ejemplo de cómo documentar controles de seguridad que ya implementaste.

Prácticas recomendadas para implementar controles de seguridad

- Realizar una evaluación de riesgos
- Identificar el control de seguridad
- Elegir soluciones
- Desarrollar un plan de implementación
- Probar y validar los controles
- Supervisar y mantener los controles

Realiza una evaluación de riesgos

Existen dos enfoques de evaluación de riesgos, uno cualitativo y otro cuantitativo. Como profesional de seguridad, una de las partes más importantes de la evaluación de riesgos es entender el recurso que quieres proteger. El recurso podrían ser datos, un proceso o personas. Recuerda que también necesitas entender los agentes de amenazas y las vulnerabilidades potenciales que podrían aprovechar, incluidos la probabilidad y el impacto de un ataque exitoso.

Crear modelos de amenazas es una buena forma de empezar a considerar la probabilidad y el impacto del riesgo. Algunos modelos de amenazas comunes incluyen lo siguiente: El proceso de simulación de ataques y análisis de amenazas (PASTA), el modelo Trike, el sistema de puntuación de vulnerabilidades comunes (CVSS), los árboles de ataque, las tarjetas de seguridad y el método híbrido de modelado de amenazas (hTMM). Cada una de estas metodologías brinda una forma diferente de evaluar las amenazas a los recursos de la organización.

Identifica los controles de seguridad

Una vez que hayas identificado las amenazas potenciales y la probabilidad de los riesgos relacionados, puedes identificar cuáles controles de seguridad son más apropiados.

Algunos ejemplos de controles de seguridad comunes para la computación en la nube son los

siguientes:

- Nombres de usuario y contraseñas (autenticación simple)
- Autenticación de dos factores
- Software antivirus
- Firewalls
- La protección contra el ataque de denegación de servicio distribuido (DDoS)
- Sistemas de prevención y detección de intrusiones
- Controles de sistemas de administración de la postura de seguridad en la nube (CSPM)

¿Cómo saber qué controles deberías usar? Puede que decidas usar un enfoque en capas o un framework como el CSF de NIST para identificar los controles adecuados. Por ejemplo, si estuvieras usando el NIST como referencia, podrías empezar por tomar un control de cada una de las funciones (Identifica, Protege, Detecta, Responde y Recupera).

Desarrolla un plan de implementación

El plan de implementación es un plan de acción que convierte tu estrategia de control de seguridad en tareas específicas. Tu plan de implementación debería ser muy claro en cuanto a cómo garantizarás que se implementen los controles requeridos. Un buen plan de implementación tiene en cuenta cómo se lanzará cada control en particular. Deberás considerar cualquier capacitación o comunicación necesarios, los costos financieros y los requisitos técnicos que se deben cumplir para aplicar el control.

Una de las dificultades más comunes en un plan de implementación es lograr que la organización lo apruebe. Esta aprobación implica voluntad y apoyo. Debes tener la aprobación y el apoyo de otras partes de la organización, incluido el departamento de TI, para que los controles tengan éxito. La aprobación de la organización es importante porque los controles son técnicos, procedimentales y administrativos. Esto significa que requieren que otros miembros de la organización participen en la implementación para que sean eficaces.

Prueba y valida

Es necesario probar los controles para confirmar o validar que estén cumpliendo los objetivos de riesgo o cumplimiento. Debes asegurarte de que los controles sean eficaces y operativos. Es importante definir y medir el éxito, y realizar evaluaciones continuas mientras se considera cualquier nueva amenaza potencial. A veces, puede haber algún cambio en el impacto o en la probabilidad de una amenaza y esto puede requerir ajustes continuos de un control o un cambio en el enfoque de control.

Supervisa y mantiene

Una vez que se implementaron con éxito los controles de seguridad, es importante supervisar

y mantener los controles de forma continua para ayudar a reducir el riesgo.

Ejemplo de documentación de controles de seguridad

La tabla de la última página de esta lectura es un ejemplo de cómo podría ser una hoja de cálculo de asignación de controles. En este ejemplo, hay cinco columnas. La primera columna describe el control de seguridad. La segunda columna asigna un nivel de riesgo, que puede ser bajo, medio o alto. La columna siguiente ofrece un espacio para que describas las razones por las que se eligió ese control. Y la última columna documenta la fuente, el estándar o el framework, según corresponda.

Nota: La plantilla para documentar controles puede variar según las necesidades organizacionales y de cumplimiento.

Conclusiones principales

Las prácticas recomendadas para identificar y aplicar controles de seguridad garantizarán que hayas implementado los controles necesarios para satisfacer las necesidades organizacionales y de cumplimiento. Documentar tus controles en un cuadro o una hoja de cálculo claros te ayudará a mostrar las evidencias y las razones por las cuales elegiste esos controles.

Recursos para obtener más información

Consulta estos recursos para obtener más información sobre la implementación de controles:

- Autenticación de varios factores para saber más sobre cómo aplicar los controles de autenticación de varios factores.
- Creación de modelos de amenazas para aprender más sobre los diferentes modelos de amenazas.

Google Cloud

Tabla de documentación de controles de seguridad

Control de seguridad	Nivel Bajo/Medio/Alto	Razones	Origen
Control de acceso: asegúrate de que los roles de propietario, editor y visualizador no estén asignados en Cloud IAM	M	Cumplir con el principio de privilegio mínimo ayuda a reducir el riesgo de explotación si las credenciales de los usuarios se vulneran por acción de un atacante externo o de un usuario malicioso con información privilegiada.	
Control de acceso: Establece Grupos de Google para representar la separación de obligaciones.	M	Cumplir con el principio de privilegio mínimo ayuda a reducir el riesgo de explotación si las credenciales de los usuarios se vulneran por acción de un atacante externo o de un usuario malicioso con información privilegiada.	Establece Grupos de Google para representar la separación de obligaciones.
Control de acceso: Brinda acceso a Grupos, cumpliendo con el principio de privilegio mínimo.	M	Cumplir con el principio de privilegio mínimo ayuda a reducir el riesgo de explotación si las credenciales de los usuarios se vulneran por acción de un atacante externo o de un usuario malicioso con información privilegiada.	Brinda acceso a los Grupos,
Identifica: Generar una lista de recursos con Cloud Asset Inventory es un Analizador de políticas o controles.	M	Estas herramientas identificarán qué programas se ejecutan y qué políticas se implementan en el entorno de nube.	CSF de NIST
Protege: controles del servicio de VPC	A	Los controles del servicio de VPC previenen que las direcciones IP no permitidas hagan alguna conexión o realicen acciones sobre los recursos.	CSF de NIST
Detecta: usa las SCC para comprender las vulnerabilidades y los cambios en la postura en la nube en relación con las comparativas.	A	Detectar y reducir las vulnerabilidades.	CSF de NIST
Responde: usa Chronicle para	M	Chronicle te ayudará a determinar el alcance y la naturaleza	CSF de NIST

iniciar la detección de amenazas y determinar el alcance y la naturaleza del ataque.		del ataque.	
Recupera: crea una copia de seguridad y restablece usando Terraform.	M	Crear una copia de seguridad y restablecer para reconstruir el entorno y que vuelva a un buen estado conocido.	CSF de NIST